DuocUC® INFORMÁTICA Y TELECOMUNICACIONES

Reconocimiento y Evaluación de Vulnerabilidades

- 1.4.1 Análisis de Vulnerabilidades

FORMAMOS PERSONAS PARA UNA SOCIEDAD MEJOR

Contenidos

- Análisis de Vulnerabilidades
- Ciclo de Gestión de Vulnerabilidades
- Herramientas de Análisis
- Mitigación
- Reporte

01

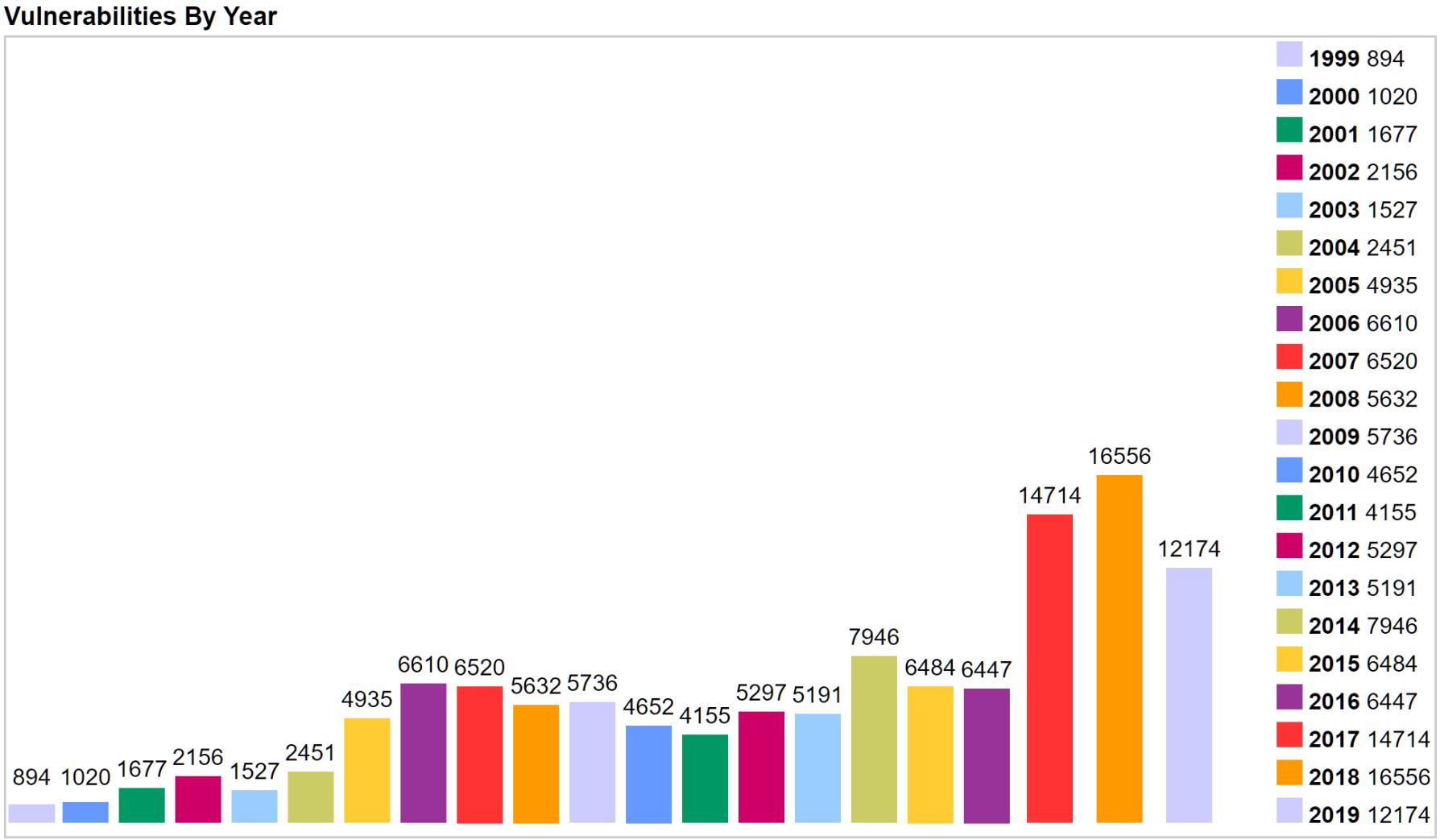
Análisis de Vulnerabilidades

Evaluación de Vulnerabilidades

Es un proceso mediante el cual la organización determina el nivel de exposición y la predisposición a la pérdida de un elemento o grupo de elementos ante una amenaza especifica. Se valora (0) la más baja a (10) en el nivel más alto o pérdida total.

El principal objetivo de este proceso es determinar el nivel de exposición que tienen los principales activos de la compañía, clasificar su nivel de riesgo y realizar el plan de mitigación o corrección de las vulnerabilidades encontradas.

Evaluación de Vulnerabilidades



Evaluación de Vulnerabilidades

	Vendor Name	Number of Products	Number of Vulnerabilities
1	Microsoft	529	6814
2	Oracle	644	6115
3	IBM	1064	4679
4	Google	84	4572
5	Apple	119	4512
6	Cisco	3676	4167
7	Adobe	132	3314
8	Debian	97	3197
9	Redhat	301	2805
10	Linux	17	2370

Análisis de Vulnerabilidades

Es el proceso en el cual se identifican y clasifican las vulnerabilidades de un sistema informático.

Para esto existen dos formas:

- Reconocimiento: a través de la información que se tiene del sistema (Ej: versión del SO) se pueden buscar las vulnerabilidades asociadas

- Scanning: a través de herramientas especializadas, que cuentan con bases de datos de vulnerabilidades, se realiza una revisión al sistema destino y se obtiene un reporte con el detalle correspondiente.

Análisis de Vulnerabilidades

Scanning de vulnerabilidades:

La herramienta más utilizada para esta función es Nessus de Tenable, está disponible para Windows y Linux y tiene una licencia pagada y una licencia gratuita

Operación de Nessus:

Nessus realiza un mapeo de todos los puertos que están abiertos en el servidor destino
A continuación, envía los plugin o firmas de tráfico que tiene configurados a los puertos disponibles

Luego recibe la respuesta del servidor para validar si la vulnerabilidad existe
y compara el resultado con su base de dato interna para validar la clasificación de las vulnerabilidades encontradas

02

Ciclo de gestión de vulnerabilidades

Ciclo de gestión de vulnerabilidades

ESCUELA DE INFORMÁTICA Y TELECOMUNICACIONES
DuocUC®

Ciclo de gestión de vulnerabilidades

Descubrimiento: en esta etapa se detallan todos los activos que formaran parte del análisis y se realiza el scanning.

Priorización: en esta etapa se define cuáles son los activos más críticos para el negocio
Evaluación: se realiza en función de la criticidad de los activos y el nivel de riesgo de las vulnerabilidades

Reporte: corresponde a la medición del nivel de riesgo encontrado en su conjunto en función de alguna base predeterminada (política)

Remediación: en esta etapa se aplican los controles en función del análisis anterior (orden de prioridad)

Verificación: se realiza una nueva medición para validar que las vulnerabilidades fueron mitigadas.

ESCUELA DE INFORMÁTICA Y TELECOMUNICACIONES

DuocUC®

Tipos de Análisis

Basado en productos:

Las empresas compran soluciones de análisis de vulnerabilidades y las operan localmente con la frecuencia requerida y luego realizan las labores de mitigación. Tiene el costo de las herramientas y las HH involucradas.

Basado en servicios:

Las empresas contratan un servicio en el cual un proveedor, en forma periódica realiza análisis de vulnerabilidades sobre un parque de servidores definido. Solo tiene el costo del servicio.

Clasificación de vulnerabilidades

Proceso en el cual se les asigna una puntuación a cada vulnerabilidad (ranking), existen diferentes criterios para realizar esta clasificación.

Clasificación CVE (CVSS): utiliza varios parámetros para realizar la calificación de puntaje, entre ellos:

- ✓ Cómo afecta la vulnerabilidad a los atributos de la información (CIA)
- ✓ La facilidad de explotación o complejidad de acceso
- ✓ Si se requiere o no autenticación para explotar la vulnerabilidad
- ✓ Los daños específicos que podría causar una vez explotada, tales como DoS, control remoto, ejecución de comandos, etc.
- ✓ Si permite o no tomar control del objetivo

ESCUELA DE INFORMÁTICA Y TELECOMUNICACIONES

DuocUC®

Clasificación de vulnerabilidades

Microsoft » Windows 10 : Security Vulnerabilities

CVSS Scores Greater Than: 0 1 2 3 4 5 6 7 8 9

Sort Results By : CVE Number Descending CVE Number Ascending CVSS Score Descending Number Of Exploits Descending

Copy Results Download Results

#	CVE ID	CWE ID	# of Exploits	Vulnerability Type(s)	Publish Date	Update Date	Score	Gained Access Level	Access
1	CVE-2021-33742			Exec Code	2021-06-08	2021-06-14	6.8	None	Remote
Windows MSHTML Platform Remote Code Execution Vulnerability									
2	CVE-2021-33739	269			2021-06-08	2021-06-14	4.6	None	Local
Microsoft DWM Core Library Elevation of Privilege Vulnerability									
3	CVE-2021-31977	119		DoS Overflow	2021-06-08	2021-06-14	5.0	None	Remote
Windows Hyper-V Denial of Service Vulnerability									
4	CVE-2021-31976	200		+Info	2021-06-08	2021-06-11	7.8	None	Remote
Server for NFS Information Disclosure Vulnerability This CVE ID is unique from CVE-2021-31975.									
5	CVE-2021-31975	200		+Info	2021-06-08	2021-06-11	7.8	None	Remote
Server for NFS Information Disclosure Vulnerability This CVE ID is unique from CVE-2021-31976.									
6	CVE-2021-31974			DoS	2021-06-08	2021-06-11	5.0	None	Remote
Server for NFS Denial of Service Vulnerability									
7	CVE-2021-31973	269			2021-06-08	2021-06-11	4.6	None	Local

ESCUELA DE INFORMÁTICA Y TELECOMUNICACIONES

DuocUC®

Clasificación de vulnerabilidades

ESCUELA DE INFORMÁTICA Y TELECOMUNICACIONES

Vulnerability Details : CVE-2021-33742

Windows MSHTML Platform Remote Code Execution Vulnerability

Publish Date : 2021-06-08 Last Update Date : 2021-06-14

Collapse All Expand All Select Select&Copy Scroll To Comments External Links

Search Twitter Search YouTube Search Google

– CVSS Scores & Vulnerability Types

CVSS Score	6.8
Confidentiality Impact	Partial (There is considerable informational disclosure.)
Integrity Impact	Partial (Modification of some system files or information is possible, but the attac scope of what the attacker can affect is limited.)
Availability Impact	Partial (There is reduced performance or interruptions in resource availability.)
Access Complexity	Medium (The access conditions are somewhat specialized. Some preconditions m
Authentication	Not required (Authentication is not required to exploit the vulnerability.)
Gained Access	None
Vulnerability Type(s)	Execute Code

Vulnerability Details : CVE-2020-1407

A remote code execution vulnerability exists when the Windows Jet Database Engine improperly ha Execution Vulnerability'. This CVE ID is unique from CVE-2020-1400, CVE-2020-1401.

Publish Date : 2020-07-14 Last Update Date : 2020-07-21

Collapse All Expand All Select Select&Copy Scroll To Comments External Links

Search Twitter Search YouTube Search Google

– CVSS Scores & Vulnerability Types

CVSS Score	9.3
Confidentiality Impact	Complete (There is total information disclosure, resulting in all system files beir
Integrity Impact	Complete (There is a total compromise of system integrity. There is a complete compromised.)
Availability Impact	Complete (There is a total shutdown of the affected resource. The attacker can
Access Complexity	Medium (The access conditions are somewhat specialized. Some preconditions
Authentication	Not required (Authentication is not required to exploit the vulnerability.)
Gained Access	None
Vulnerability Type(s)	Execute Code Overflow

DuocUC®

Clasificación según Nessus

En este caso se utiliza un código de colores para la clasificación de las vulnerabilidades en 5 niveles

Ejemplo de clasificación de vulnerabilidades según Nessus de Tenable:

critical	MS08-067: Microsoft Windows Server Service Crafted RPC	Windows	1
critical	MS09-001: Microsoft Windows SMB Vulnerabilities Remote Code	Windows	1
high	MS02-045: Microsoft Windows SMB Protocol	Windows	1
high	MS06-035: Vulnerability in Server Service Could Allow Remote...	Windows	1
medium	Microsoft Windows SMB NULL Session Authentication	Windows	1
medium	MS05-007: Vulnerability in Windows Could Allow Information D...	Windows	1
medium	SMB Signing Disabled	Misc.	1
low	Multiple Ethernet Driver Frame Padding Information Disclosur...	Misc.	1

ESCUELA DE INFORMÁTICA Y TELECOMUNICACIONES

DuocUC®

03

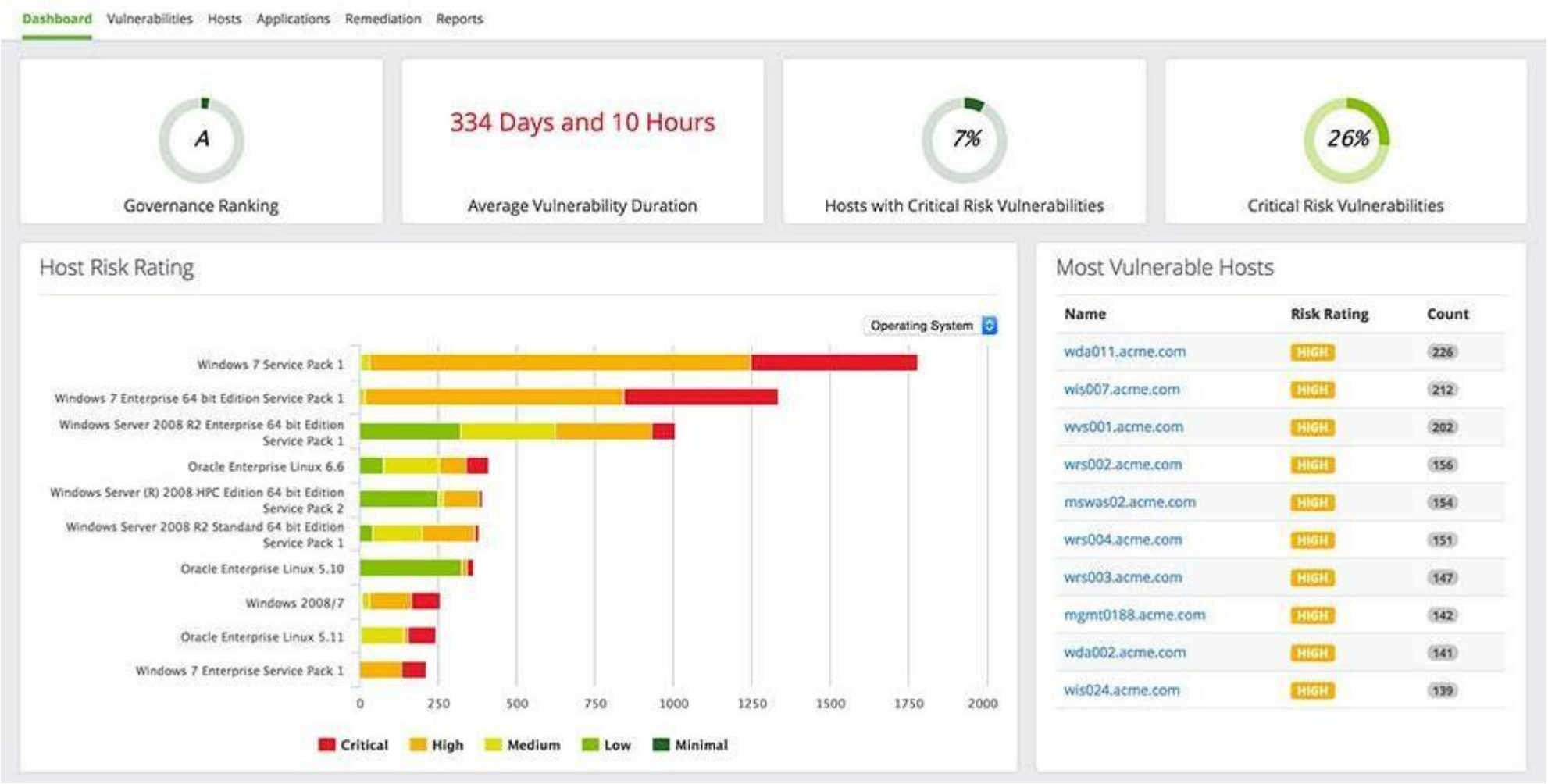
Herramientas de Análisis

Herramientas de Análisis

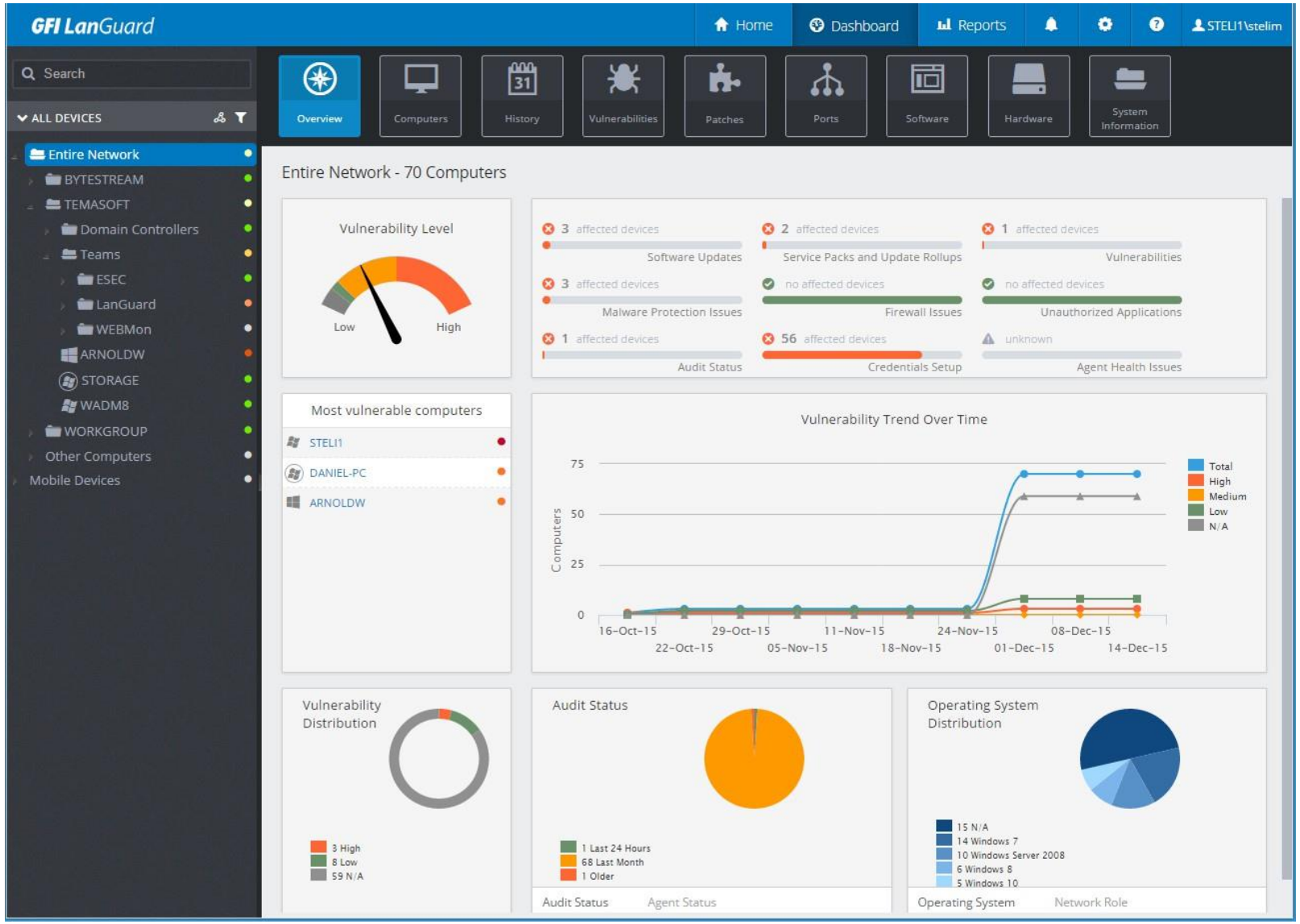
Características de una buena herramienta de análisis de vulnerabilidades:

- ✓ Debe tener una gran base de datos con plugin de vulnerabilidades conocidas
- ✓ Soportar múltiples plataformas y sistemas operativos
- ✓ Tener una alta precisión en la búsqueda de vulnerabilidades
- ✓ Actualización automática
- ✓ Generación de reportes amigables
- ✓ Programación de análisis

Qualys


Dashboard
Vulnerabilities
Hosts
Applications
Remediation
Reports
A
Governance Ranking
334 Days and 10 Hours
Average Vulnerability Duration
7%
Hosts with Critical Risk Vulnerabilities
26%
Critical Risk Vulnerabilities
Host Risk Rating
Operating System
Windows 7 Service Pack 1
Windows 7 Enterprise 64 bit Edition Service Pack 1
Windows Server 2008 R2 Enterprise 64 bit Edition Service Pack 1
Oracle Enterprise Linux 6.6
Windows Server (R) 2008 HPC Edition 64 bit Edition Service Pack 2
Windows Server 2008 R2 Standard 64 bit Edition Service Pack 1
Oracle Enterprise Linux 5.10
Windows 2008/7
Oracle Enterprise Linux 5.11
Windows 7 Enterprise Service Pack 1
0
250
500
750
1000
1250
1500
1750
2000
Critical
High
Medium
Low
Minimal
Most Vulnerable Hosts
Name
Risk Rating
Count
wda011.acme.com HIGH 226
wis007.acme.com HIGH 212
wvs001.acme.com HIGH 202
wrs002.acme.com HIGH 156
mswas02.acme.com HIGH 154
wrs004.acme.com HIGH 151
wrs003.acme.com HIGH 147
mgmt0188.acme.com HIGH 142
wda002.acme.com HIGH 141
wis024.acme.com HIGH 139

GFI LanGuard

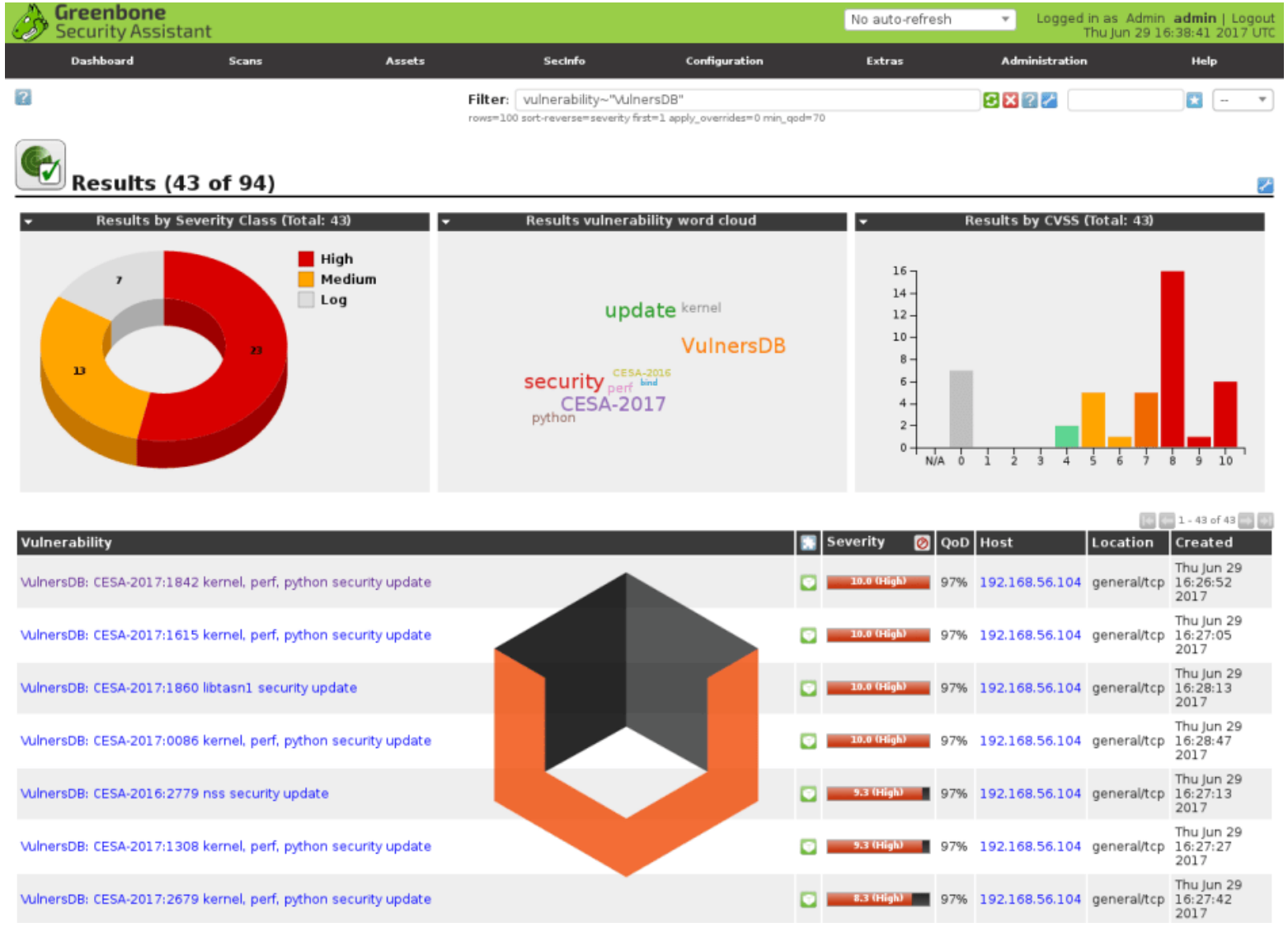


Nikto

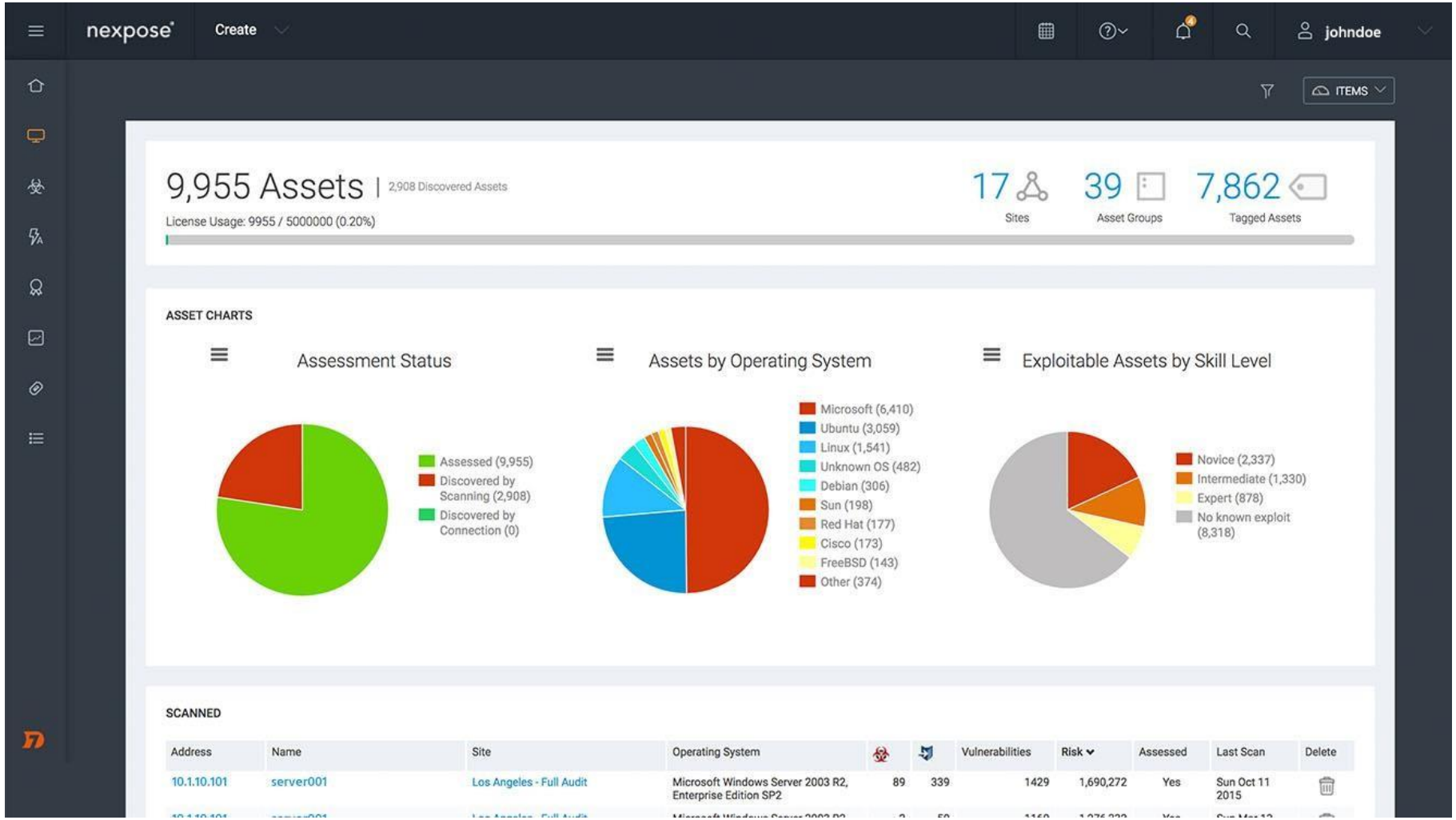
```
root@bt: /pentest/web/nikto
File  Edit  View  Terminal  Help
# nikto -h 192.168.18.132 -p 80,443

---------------------------------------------------------------------------
+ No web server found on 192.168.18.132:443
---------------------------------------------------------------------------
+ Target IP:          192.168.18.132
+ Target Hostname:    192.168.18.132
+ Target Port:        80
+ Start Time:         2013-02-24 12:27:27 (GMT-5)
---------------------------------------------------------------------------
+ Server: Apache/2.2.8 (Ubuntu) PHP/5.2.4-2ubuntu5.10 with Suhosin-Patch
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.2.19). Apache 1.3.42
(final release) and 2.0.64 are also current.
+ PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 5.3.6)
+ Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE
+ OSVDB-877: HTTP TRACE method is active, suggesting the host is vulnerable to XST
+ Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10
+ OSVDB-3233: /phpinfo.php: Contains PHP configuration information
+ OSVDB-3268: /icons/: Directory indexing found.
+ OSVDB-3233: /icons/README: Apache default file found.
+ OSVDB-40478: /tikiwiki/tiki-graph_formula.php?w=1&h=1&s=1&min=1&max=2&f[]=x.tan.phpinfo
()&t=png&title=http://cirt.net/rfiinc.txt?: TikiWiki contains a vulnerability which allow
s remote attackers to execute arbitrary PHP code.
+ 6474 items checked: 2 error(s) and 9 item(s) reported on remote host
+ End Time:           2013-02-24 12:28:20 (GMT-5) (53 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
root@bt:/pentest/web/nikto#
```

OpenVas


Greenbone
Security Assistant
No auto-refresh
Logged in as Admin admin | Logout
Thu Jun 29 16:38:41 2017 UTC
Dashboard
Scans
Assets
SecInfo
Configuration
Extras
Administration
Help
Filter: vulnerability~"VulnersDB"
rows=100 sort-reverse=severity first=1 apply_overrides=0 min_qod=70
Results (43 of 94)
Results by Severity Class (Total: 43)
High
Medium
Log
7
13
23
Results vulnerability word cloud
update
kernel
VulnersDB
security
CESA-2016
perf
bind
CESA-2017
python
Results by CVSS (Total: 43)
16
14
12
10
8
6
4
2
0
N/A
0
1
2
3
4
5
6
7
8
9
10
1 - 43 of 43
Vulnerability
Severity
QoD
Host
Location
Created
VulnersDB: CESA-2017:1842 kernel, perf, python security update
10.0 (High)
97%
192.168.56.104
general/tcp
Thu Jun 29 16:26:52 2017
VulnersDB: CESA-2017:1615 kernel, perf, python security update
10.0 (High)
97%
192.168.56.104
general/tcp
Thu Jun 29 16:27:05 2017
VulnersDB: CESA-2017:1860 libtasn1 security update
10.0 (High)
97%
192.168.56.104
general/tcp
Thu Jun 29 16:28:13 2017
VulnersDB: CESA-2017:0086 kernel, perf, python security update
10.0 (High)
97%
192.168.56.104
general/tcp
Thu Jun 29 16:28:47 2017
VulnersDB: CESA-2016:2779 nss security update
9.3 (High)
97%
192.168.56.104
general/tcp
Thu Jun 29 16:27:13 2017
VulnersDB: CESA-2017:1308 kernel, perf, python security update
9.3 (High)
97%
192.168.56.104
general/tcp
Thu Jun 29 16:27:27 2017
VulnersDB: CESA-2017:2679 kernel, perf, python security update
8.3 (High)
97%
192.168.56.104
general/tcp
Thu Jun 29 16:27:42 2017

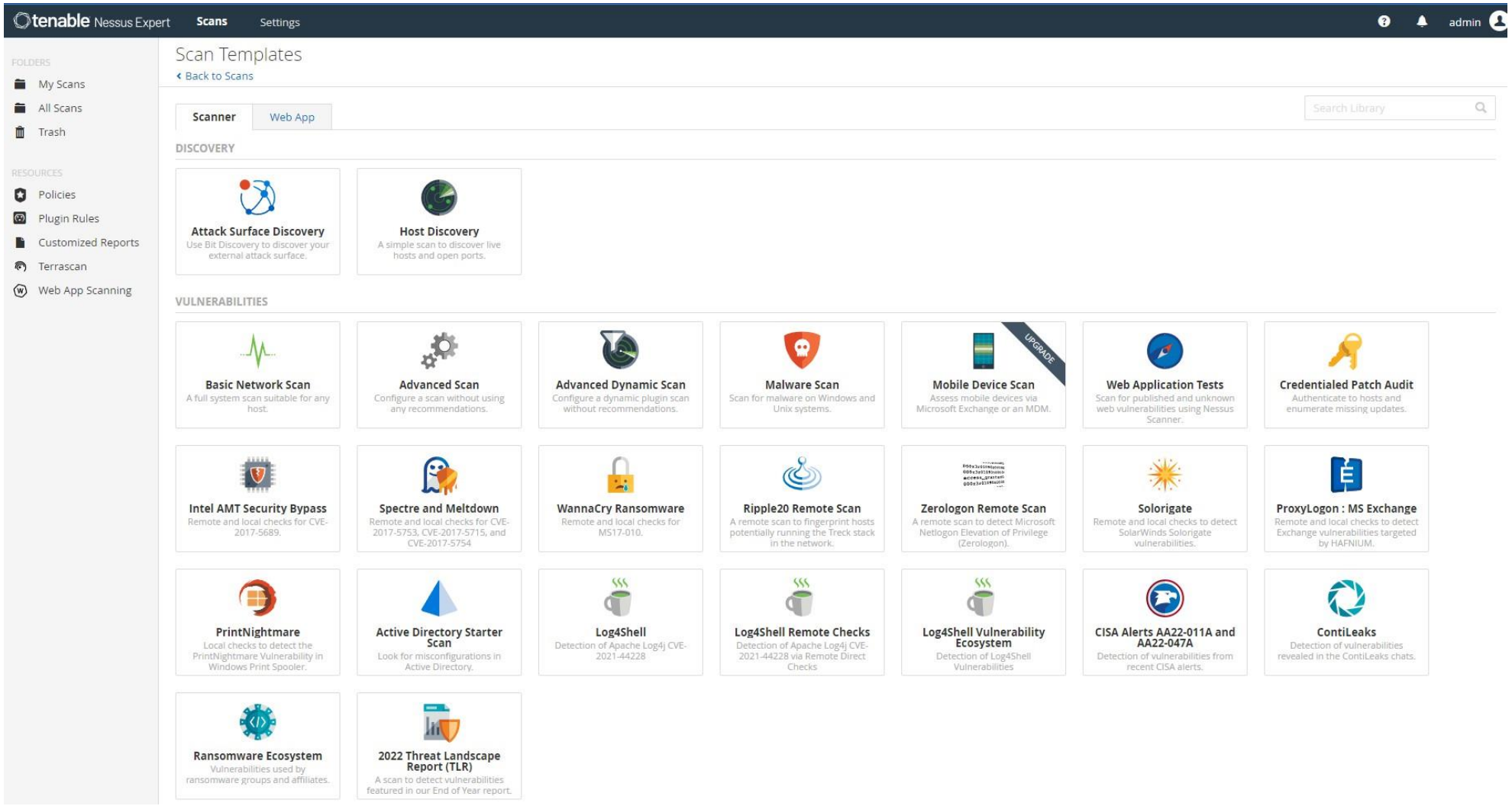
Nexpose


nexpose
Create
johndoe
ITEMS
9,955 Assets | 2,908 Discovered Assets
License Usage: 9955 / 5000000 (0.20%)
17 Sites
39 Asset Groups
7,862 Tagged Assets
ASSET CHARTS
Assessment Status
Assessed (9,955)
Discovered by Scanning (2,908)
Discovered by Connection (0)
Assets by Operating System
Microsoft (6,410)
Ubuntu (3,059)
Linux (1,541)
Unknown OS (482)
Debian (306)
Sun (198)
Red Hat (177)
Cisco (173)
FreeBSD (143)
Other (374)
Exploitable Assets by Skill Level
Novice (2,337)
Intermediate (1,330)
Expert (878)
No known exploit (8,318)
SCANNED
Address
Name
Site
Operating System
Vulnerabilities
Risk
Assessed
Last Scan
Delete
10.1.10.101
server001
Los Angeles - Full Audit
Microsoft Windows Server 2003 R2, Enterprise Edition SP2
89
339
1429
1,690,272
Yes
Sun Oct 11 2015

Acunetix

acunetix360
11
High Severity Vulnerabilities
18
Medium Severity Vulnerabilities
14
Low Severity Vulnerabilities
4 User
20 Websites
12 Completed Scan
10 Act. Vulnerabilities
Open Vulnerabilities
Recents Scans
Top Vulnerabilities
Open Vulnerabilities
Average Time to Fix

Nessus


tenable Nessus Expert
Scans
Settings
admin
FOLDERS
My Scans
All Scans
Trash
RESOURCES
Policies
Plugin Rules
Customized Reports
Terrascan
Web App Scanning
Scan Templates
Back to Scans
Scanner
Web App
Search Library
DISCOVERY
Attack Surface Discovery
Use Bit Discovery to discover your external attack surface.
Host Discovery
A simple scan to discover live hosts and open ports.
VULNERABILITIES
Basic Network Scan
A full system scan suitable for any host.
Advanced Scan
Configure a scan without using any recommendations.
Advanced Dynamic Scan
Configure a dynamic plugin scan without recommendations.
Malware Scan
Scan for malware on Windows and Unix systems.
UPGRADE
Mobile Device Scan
Assess mobile devices via Microsoft Exchange or an MDM.
Web Application Tests
Scan for published and unknown web vulnerabilities using Nessus Scanner.
Credentialed Patch Audit
Authenticate to hosts and enumerate missing updates.
Intel AMT Security Bypass
Remote and local checks for CVE-2017-5689.
Spectre and Meltdown
Remote and local checks for CVE-2017-5753, CVE-2017-5715, and CVE-2017-5754
WannaCry Ransomware
Remote and local checks for MS17-010.
Ripple20 Remote Scan
A remote scan to fingerprint hosts potentially running the Treck stack in the network.
Zerologon Remote Scan
A remote scan to detect Microsoft Netlogon Elevation of Privilege (Zerologon).
Solorigate
Remote and local checks to detect SolarWinds Solorigate vulnerabilities.
ProxyLogon : MS Exchange
Remote and local checks to detect Exchange vulnerabilities targeted by HAFNIUM.
PrintNightmare
Local checks to detect the PrintNightmare Vulnerability in Windows Print Spooler.
Active Directory Starter Scan
Look for misconfigurations in Active Directory.
Log4Shell
Detection of Apache Log4j CVE-2021-44228
Log4Shell Remote Checks
Detection of Apache Log4j CVE-2021-44228 via Remote Direct Checks
Log4Shell Vulnerability Ecosystem
Detection of Log4Shell Vulnerabilities
CISA Alerts AA22-011A and AA22-047A
Detection of vulnerabilities from recent CISA alerts.
ContiLeaks
Detection of vulnerabilities revealed in the ContiLeaks chats.
Ransomware Ecosystem
Vulnerabilities used by ransomware groups and affiliates.
2022 Threat Landscape Report (TLR)
A scan to detect vulnerabilities featured in our End of Year report.

Nmap

```
root@kali:~# nmap --script-args=unsafe=1 --script smb-check-vulns.nse -p445 192.
168.1.121

Starting Nmap 6.46 ( http://nmap.org ) at 2014-11-21 16:42 MST
Nmap scan report for 192.168.1.121
Host is up (0.0027s latency).
PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:18:6B:DB (VMware)

Host script results:
| smb-check-vulns:
|   MS08-067: VULNERABLE
|   Conficker: Likely CLEAN
|   SMBv2 DoS (CVE-2009-3103): NOT VULNERABLE
|   MS06-025: NOT VULNERABLE
|_  MS07-029: NO SERVICE (the Dns Server RPC service is inactive)

Nmap done: 1 IP address (1 host up) scanned in 18.74 seconds
```

Recomendaciones de Mitigación

Ejemplo de un reporte de Nessus:

Description

The remote version of Windows contains a flaw in the Server Message Block (SMB) implementation that could allow an attacker to execute arbitrary code on the remote host.

An attacker does not need to be authenticated to exploit this flaw.

Solution

Microsoft has released a set of patches for Windows 2000, XP and 2003 :

http://technet.microsoft.com/en-us/security/bulletin/ms05-027

Plugin Information

Plugin ID: 18483
Plugin Version: $Revision: 1.32 $
Plugin Type: local
Plugin Publication Date: 2005/06/14
Plugin Last Modification Date: 2013/02/01

Software description

- openssl - Secure Socket Layer (SSL) cryptographic library and tools

Details

Anton Johansson discovered that OpenSSL incorrectly handled certain invalid TLS handshakes. A remote attacker could use this issue to cause OpenSSL to crash, resulting in a denial of service. (CVE-2013-4353)

Ron Barber discovered that OpenSSL used an incorrect data structure to obtain a version number. A remote attacker could use this issue to cause OpenSSL to crash, resulting in a denial of service. (CVE-2013-6449)

Dmitry Sobinov discovered that OpenSSL incorrectly handled certain DTLS retransmissions. A remote attacker could use this issue to cause OpenSSL to crash, resulting in a denial of service. (CVE-2013-6450)

This update also disables the default use of the RdRand feature of certain Intel CPUs as the sole source of entropy.

Update instructions

The problem can be corrected by updating your system to the following package version:

Ubuntu 13.10:

libssl1.0.0 1.0.1e-3ubuntu1.1

Ubuntu 13.04:

libssl1.0.0 1.0.1c-4ubuntu8.2

Reporte

- ✓ Resumen ejecutivo
- ✓ Sistemas vulnerables
- ✓ Descripción de la vulnerabilidad
- ✓ Clasificación de riesgo
- ✓ Mitigación
- ✓ Sistemas afectados
- ✓ Referencias
- ✓ Recomendaciones

Sev	Name	Family	Count
CRITICAL	Bash Incomplete Fix Remote Code Execution Vulner…	Gain a shell remotely	3
CRITICAL	Bash Remote Code Execution (CVE-2014-6277 / CV…	Gain a shell remotely	3
CRITICAL	Bash Remote Code Execution (Shellshock)	Gain a shell remotely	3
CRITICAL	CentOS 4 / 5 / 6 : firefox (CESA-2012:0079)	CentOS Local Security Checks	1
CRITICAL	CentOS 4 / 5 : firefox / xulrunner (CESA-2011:1164)	CentOS Local Security Checks	1
CRITICAL	CentOS 4 / 5 : krb5 (CESA-2011:1851)	CentOS Local Security Checks	1
CRITICAL	CentOS 5 / 6 / 7 : bash (CESA-2014:1293)	CentOS Local Security Checks	1
CRITICAL	CentOS 5 / 6 / 7 : bash (CESA-2014:1306)	CentOS Local Security Checks	1

04

Conclusiones

Conclusiones

- El análisis de vulnerabilidades identifica debilidades en los sistemas.
- Las vulnerabilidades deben clasificarse y priorizarse según su criticidad.
- Herramientas robustas y actualizadas son esenciales para un análisis efectivo.
- La gestión continua de vulnerabilidades garantiza una protección adecuada.

Duoc UC®

CERCANÍA. LIDERAZGO. FUTURO.

duoc.cl

7 AÑOS ACREDITADO

Comisión Nacional de Acreditación CNA-Chile

DESDE AGOSTO 2017 HASTA AGOSTO 2024.
DOCENCIA DE PREGRADO. GESTIÓN INSTITUCIONAL. VINCULACIÓN CON EL MEDIO.